

20262809 《Linux内核原理与分析》第十一周作业

****学号：****20262809

****姓名：****叶丁再（请确保与证书申请姓名一致）

阅读范围：《庖丁解牛 Linux 操作系统分析》第十二章

****日期：****2026 年 9 月 27 日

****原创作品转载请注明出处：****叶丁再

课程：《Linux 内核分析》MOOC 课程 <http://mooc.study.163.com/course/USTC-1000029000>

一、阅读问题：Linux 安全要保护什么

第十二章“Linux 系统安全相关技术”从安全目标、访问控制讲到可信计算。阅读时我先把安全目标归纳为机密性、完整性和可用性：机密性关注信息是否被不该访问的人看到，完整性关注数据和系统状态是否被未授权改变，可用性关注服务能否正常提供。认证、授权和审计分别回答“你是谁”“你能做什么”“发生了什么”，它们相互配合，但不是同一件事。

我由此理解，安全不是某一条权限规则或某个安全软件的单点功能。分层防御需要结合身份管理、最小权限、访问控制、日志审计、系统更新和隔离机制。某项检查或日志只能提供一类证据，不能单独证明系统整体安全。

二、阅读问题：文件权限和访问控制模型有什么关系

1. DAC、MAC 和 RBAC 分别从哪里判断权限？

Linux 常见文件权限体现了自主访问控制（DAC）：文件所有者可以通过属主、属组和其他用户的读、写、执行权限管理访问。它灵活且易于理解，但权限配置错误可能造成敏感文件泄露。强制访问控制（MAC）再依据系统策略和安全标签限制访问，普通文件所有者不能随意绕过策略。基于角色的访问控制（RBAC）则把权限关联到角色，再把用户映射到角色，方便按职责组织授权。

教材用 Bell-LaPadula 和 Biba 说明强制访问控制的安全目标：前者侧重机密性，后者侧重完整性。它们通过安全级别和读写规则约束信息流。RBAC 与它们关注角度不同：RBAC 以角色组织权限；MAC 以系统定义的策略和安全属性作出访问决定。实际系统可以组合使用不同机制。

机制	判断访问的主要依据	我对它的理解
DAC	文件属主、属组及传统权限位	资源所有者参与决定谁可以访问
MAC	系统策略、安全级别或安全标签	访问受系统策略约束，不能只由文件所有者决定
RBAC	用户、角色及角色对应的权限	先按职责组织权限，再把用户映射到角色

2. `/etc/passwd`、`/etc/shadow` 和文件元数据分别能说明什么？

教材介绍了 Linux 用户信息和口令信息的分离：`/etc/passwd` 保存用户标识、UID、GID、家目录和 Shell 等信息；口令哈希及口令期限等信息放在权限更严格的 `/etc/shadow` 中。示例中 `/etc/passwd` 的第二字段为 `x`，表示口令信息转到 `shadow` 文件。这里讲的是账户数据库文件格式，不能把字段内容误当成登录认证本身。

文件权限之外，inode 还记录文件类型、所有者、权限、大小、时间戳和链接等元数据。查看元数据可帮助调查异常，但某个时间戳或权限变化本身不能证明入侵；应结合系统日志、可信基线、操作上下文和其他证据判

断。教材还提到可用不可变或仅追加属性保护关键文件与日志。此类属性会影响正常维护，应按系统管理策略谨慎配置，而不是对所有文件一概使用。

三、阅读问题：Linux 如何把传统权限扩展为更细的控制

1. Capabilities 为什么能缩小 root 权限？

传统上，特权操作容易与完整的 root 权限绑定。Linux Capabilities 把部分管理权限拆分成较小的能力集合，例如网络管理、系统时间设置或进程跟踪等。程序在完成特定管理任务时，只需获得所需能力，有助于遵循最小权限原则，缩小进程被攻破后的影响范围。

教材还区分了访问控制列表与能力列表：访问控制列表从对象一侧记录主体及其权限；能力列表从主体一侧记录它可访问哪些对象、执行哪些操作。Capabilities 适用于比文件访问更广的特权管理。不过，“拆分权限”并不自动保证安全，能力的授予、继承和使用仍需按实际任务限制。

2. AppArmor 与 SELinux 的约束方式有何差别？

两者都是 Linux 安全模块（LSM）框架上的访问控制方案。LSM 通过内核关键访问路径上的安全检查点（hook）调用安全模块的判断逻辑，为传统 DAC 增加额外的策略检查。

教材主要通过配置方式帮助区分它们：AppArmor 通常以应用程序关联的 profile 描述可访问路径和资源，具有较强的路径导向特征；教材介绍的 SELinux 则把进程和对象关联到安全上下文标签，由策略决定某个主体能否对某类对象执行某项操作。SELinux 的标签示例包含用户、角色、类型和安全级别等部分。可以把前者概括为围绕程序 profile 组织规则，把后者概括为围绕标签和策略作访问判断；这只是帮助理解的简化，实际规则和实现细节应以目标系统文档为准。

SELinux 的 permissive 模式会记录策略拒绝但不阻止访问，enforcing 模式会执行策略；disabled 则不启用该机制。AppArmor 也有执行限制和学习/抱怨模式。调试策略时，记录拒绝信息有助于发现缺失规则，但“只记录不拦截”不是最终的强制防护状态。是否启用、如何切换以及配置文件位置会随发行版和版本变化，不能直接照搬教材中的服务命令或配置路径。

3. seccomp 在安全体系中扮演什么角色？

教材把 seccomp 描述为对进程系统调用施加约束的机制。与按文件对象或安全标签判定访问不同，seccomp 关注进程能够发起哪些系统调用及其处理方式。它适合缩小程序可使用的内核接口范围，但并不能代替用户权限、文件访问控制或应用自身的安全设计。多种机制组合起来，才能覆盖不同攻击面。

四、阅读问题：可信计算和机密计算分别解决什么问题

可信计算强调以硬件安全机制建立受保护的执行环境，并验证启动或运行环境的可信状态。教材回顾了 TPM/TCM、动态可信根以及 ARM TrustZone 等思路：目标是在硬件和软件配合下建立信任链，并隔离敏感代码或数据。可信执行环境（TEE）可为特定任务提供与普通执行环境隔离的空间。

机密计算进一步关注“数据正在被处理时如何保护”。教材以 Intel SGX enclave 为例，说明敏感代码和数据可在隔离区域中运行；并介绍华为 secGear 以 Base、Middleware、Service 三层提供统一接口、开发支持和安全服务，示例展示了 EDL 接口、CMake 配置以及安全侧和非安全侧代码的配合。

我把两者的关系理解为：可信计算关注执行环境如何建立信任，机密计算关注运行中数据和代码如何受到隔离保护。它们都依赖硬件、固件、操作系统、工具链和应用的配合，不是装上某个框架就自动获得绝对安全。书

中的 secGear 版本、支持的处理器、操作系统和 SGX/TrustZone 配置都有明确环境条件；示例命令是教材中的开发流程，并非我在本机完成的实测。

五、我的理解

读完本章，我对 Linux 安全的理解从“设置好文件权限”扩展为多个层次的共同作用：身份和账户确定主体，DAC 提供基础的对象权限，Capabilities 把特权拆分，LSM 安全模块再按策略检查访问，seccomp 等机制可以进一步限制系统调用面，日志与审计则帮助追踪和复核事件。可信执行环境与机密计算把保护边界延伸到硬件支持的隔离空间。

这些机制解决的问题不同，不能互相替代。例如，SELinux 的策略检查不能取代安全的软件更新，Capabilities 不能替代正确的文件权限，机密计算也不能证明应用逻辑本身没有缺陷。实际防护应从威胁和所需权限出发，选择合适的控制，并通过日志和测试确认策略按预期工作。

阅读范围与说明

本文根据《庖丁解牛 Linux 操作系统分析》第十二章“Linux 系统安全相关技术”（教材印刷页 354–394）整理。本文是教材阅读总结，没有执行书中的 AppArmor、SELinux 或 secGear 命令，也没有把示例配置写成个人实验结果。书中关于具体发行版、配置路径和硬件支持的描述应以目标系统当前文档为准。

参考资料

1. 孟宁、娄嘉鹏：《庖丁解牛 Linux 操作系统分析》，第十二章“Linux 系统安全相关技术”，第 354–394 页。
2. 《Linux 内核分析》MOOC 课程：<http://mooc.study.163.com/course/USTC-1000029000>